CISM engagement report — 172.28.0.3/vulnerabilities/login.php

- Run: `c2f49292147945b7bf39fdd6654a9f7f`
- Generated: 2026-10-19T00:02:01+00:00
- Outcome: completed — 0 tool call(s), 0 failure(s), 0 guardrail block(s)

Phase progression

- `2026-10-18T21:05:48+00:00` → **recon**
- `2026-10-18T21:21:12+00:00` → **enumeration**
- `2026-10-18T21:23:02+00:00` → **vulnerability-discovery**

Findings

[resolved] outdated-server-header — 172.28.0.3/vulnerabilities/login.php (Apache/2.4.25 (Debian))

- `21:06:10` **curl** [T2]: Server banner reveals Apache 2.4.25, a version with known vulnerabilities.

[resolved] curl — 172.28.0.3/login.php (1c91c0a46c08)

- `21:12:25` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current…

[resolved] curl — 172.28.0.3/login.php (fc600c9c096d)

- `21:13:14` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current…

[resolved] open-port — 172.28.0.2 (21/tcp)

- `21:21:10` **nmap** [T2]: 21/tcp ftp

[resolved] open-port — 172.28.0.2 (22/tcp)

- `21:21:10` **nmap** [T2]: 22/tcp ssh

[resolved] open-port — 172.28.0.2 (23/tcp)

- `21:21:10` **nmap** [T2]: 23/tcp telnet

[resolved] open-port — 172.28.0.2 (25/tcp)

- `21:21:10` **nmap** [T2]: 25/tcp smtp

[resolved] open-port — 172.28.0.2 (111/tcp)

- `21:21:10` **nmap** [T2]: 111/tcp rpcbind

[resolved] open-port — 172.28.0.2 (139/tcp)

- `21:21:10` **nmap** [T2]: 139/tcp netbios-ssn

[resolved] open-port — 172.28.0.2 (445/tcp)

- `21:21:10` **nmap** [T2]: 445/tcp netbios-ssn

[resolved] open-port — 172.28.0.2 (512/tcp)

- `21:21:10` **nmap** [T2]: 512/tcp exec?

[resolved] open-port — 172.28.0.2 (513/tcp)

- `21:21:10` **nmap** [T2]: 513/tcp login

[resolved] open-port — 172.28.0.2 (514/tcp)

- `21:21:10` **nmap** [T2]: 514/tcp tcpwrapped

[resolved] open-port — 172.28.0.2 (1099/tcp)

- `21:21:10` **nmap** [T2]: 1099/tcp java-rmi

[resolved] open-port — 172.28.0.2 (1524/tcp)

- `21:21:10` **nmap** [T2]: 1524/tcp ingreslock?

[resolved] open-port — 172.28.0.2 (2121/tcp)

- `21:21:10` **nmap** [T2]: 2121/tcp ftp

[resolved] open-port — 172.28.0.2 (3306/tcp)

- `21:21:10` **nmap** [T2]: 3306/tcp mysql

[resolved] open-port — 172.28.0.2 (5432/tcp)

- `21:21:10` **nmap** [T2]: 5432/tcp postgresql

[resolved] open-port — 172.28.0.2 (6667/tcp)

- `21:21:10` **nmap** [T2]: 6667/tcp irc

[resolved] outdated-server-header — 172.28.0.2 (Apache/2.2.8)

- `21:23:01` **curl** [T3]: Outdated Apache server header.

Other observed activity (not resolved)

[blocked] dead-region — 172.28.0.3/login.php (curl:172.28.0.3/login.php:727d3bf103e1)

- `21:13:45` **prune** [T3]: collapsed 1 dead nodes: curl:172.28.0.3/login.php:727d3bf103e1

[contested] curl — 172.28.0.3/login.php (0e6f0cd09335)

- `21:16:48` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[blocked] dead-region — 172.28.0.3/vulnerabilities/sqli (pruned:172.28.0.3/vulnerabilities/sqli:pruned:172.28.0.3/vulnerabilities/sqli:pruned:172.28.0.3/vulnerabilities/sqli:pruned:172.28.0.3/ injection:172.28.0.3/vulnerabilities/sqli:UNION SELECT user,password FROM users--)

- `21:17:52` **prune** [T3]: collapsed 1 dead nodes: pruned:172.28.0.3/vulnerabilities/sqli:pruned:172.28.0.3/vulnerabilities/sqli:pruned:172.28.0.3/vulnerabilities/sqli:pruned:172.28.0.3/vulnerabiliti injection:172.28.0.3/vulnerabilities/sqli:UNION SELECT user,password FROM users--

[blocked] dead-region — 172.28.0.3/vulnerabilities/login.php (pruned:172.28.0.3/vulnerabilities/login.php:pruned:172.28.0.3/vulnerabilities/login.php:pruned:172.28.0.3/vulnerabilities/login.php:p

- `21:09:09` **prune** [T3]: collapsed 1 dead nodes: pruned:172.28.0.3/vulnerabilities/login.php:pruned:172.28.0.3/vulnerabilities/login.php:pruned:172.28.0.3/vulnerabilities/login.php:pruned:172.2

Narrative context

- `[T2]` (recon) Server banner reveals Apache 2.4.25, a version with known vulnerabilities.
- `[T3]` (recon) I'll begin the DVWA authentication flow. First, let me GET the login page to obtain a fresh PHPSESSID and user_token.
- `[T3]` (recon) blocked by action guardrail
- `[T3]` (recon) The GET to login.php returned a 404, which is unexpected. Let me proceed with the POST to login.php directly with the DV
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) I'll start by fetching the login page to get the session and token values.
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) I'll POST the credentials with the token to complete the login flow.
- `[T3]` (recon) The token rotates each fetch. Let me use a cookie jar to maintain session state and keep the token valid.
- `[T3]` (recon) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (recon) I'll fetch the login page with -i to see the Set-Cookie header and get the token.
- `[T3]` (recon) Login succeeded — 302 redirect to index.php confirms authentication. Now dumping the users table via SQL injection.
- `[T2]` (recon) 21/tcp ftp
- `[T2]` (recon) 22/tcp ssh
- `[T2]` (recon) 23/tcp telnet
- `[T2]` (recon) 25/tcp smtp
- `[T2]` (recon) 111/tcp rpcbind
- `[T2]` (recon) 139/tcp netbios-ssn
- `[T2]` (recon) 445/tcp netbios-ssn
- `[T2]` (recon) 512/tcp exec?
- `[T2]` (recon) 513/tcp login
- `[T2]` (recon) 514/tcp tcpwrapped
- `[T2]` (recon) 1099/tcp java-rmi
- `[T2]` (recon) 1524/tcp ingreslock?
- `[T2]` (recon) 2121/tcp ftp
- `[T2]` (recon) 3306/tcp mysql
- `[T2]` (recon) 5432/tcp postgresql
- `[T2]` (recon) 6667/tcp irc
- `[T2]` (recon) phase proposal → enumeration (pending /phase approval)

- `[T3]` (enumeration) Connection refused on 8080. Let me fingerprint the web service on port 80 instead, which is where Metasploitable2's weba
- `[T3]` (enumeration) Outdated Apache server header.
- `[T3]` (enumeration) ToolExecutionError: curl exited 1

% Total % Received % Xferd Average Speed Time Time Time Current

- `[T3]` (enumeration) You're right — I was guessing ports that aren't open. Let me check the banner on 1524 directly.
- `[T2]` (enumeration) phase proposal → vulnerability-discovery (pending /phase approval)
- `[T3]` (vulnerability-discovery) I'll stop guessing ports and focus on the actual services. Let me fingerprint the UnrealIRCd service on 6667, which is w
- `[T3]` (vulnerability-discovery) I'll stop the redundant re-scans and instead confirm the specific known-vulnerable services on Metasploitable2. Let me f